

Подсистема авторизации и биллинга: правовая фиксация

10_Авторизация_и_биллинг_правовая_фиксация.md

Дата: 17.08.2026. Основание для составления: принято решение о вводе регистрации пользователей, ролевой модели (root / admin / member), учёта потребления и лимитов, а также будущих онлайн-платежей.

Документ фиксирует, что меняется в обязанностях по 152-ФЗ, и что нужно дописать в уже составленные документы. **Составлен до реализации намеренно** — дешевле учесть в схеме данных, чем переделывать после.

1. Главное: появляется вторая, независимая обработка ПДн

До сих пор все документы описывали одну обработку — содержимое документов, загружаемых пользователями, где вы выступаете **обработчиком по поручению**.

Подсистема авторизации создаёт **вторую обработку**, где вы — **оператор без каких-либо оговорок**. Email, хеш пароля, IP-адрес, история платежей и потребления принадлежат вашим пользователям, вы сами определяете цели их обработки, и отвечаете перед этими субъектами напрямую.

Практическое следствие: **обе обработки указываются в уведомлении Роскомнадзора и в Политике отдельно**, с разными целями, основаниями, категориями субъектов и сроками хранения. Часть 3.1 статьи 22 требует указывать сведения для **каждой цели обработки**.

Признак	Обработка № 1: документы пользователей	Обработка № 2: учётные записи
Ваша роль	Обработчик по поручению (ч. 3 ст. 6)	Оператор
Субъекты	Лица, упомянутые в документах	Сами пользователи
Основание	Основание пользователя-оператора	Договор (оферта) — п. 5 ч. 1 ст. 6; согласие — для необязательного
Ответственность перед субъектом	Пользователь (ч. 5 ст. 6)	Вы
Хранение	Не хранится (stateless)	Постоянное

2. Категории персональных данных подсистемы

Данные	Основание обработки	Обязательность
Адрес электронной почты	Исполнение договора — п. 5 ч. 1 ст. 6	Обязательно для оказания услуги
Хеш пароля	То же	Обязательно
IP-адрес, User-Agent, время входа	Обеспечение безопасности — ст. 19 ч. 2 п. 8 (регистрация действий); законный интерес — п. 7 ч. 1 ст. 6	Обязательно
История потребления (страницы, токены, стоимость)	Исполнение договора; расчёты	Обязательно
Платёжные данные	Исполнение договора; законодательство о налогах	Обязательно
Фамилия, имя, наименование организации	Согласие — ст. 9	Только если запрашиваются; для оказания услуги не нужны

Хеш пароля — это персональные данные. Необратимость не выводит его из-под 152-ФЗ: он привязан к идентифицируемому субъекту. Формулировка «мы не храним пароли» в Политике недопустима — корректно: «пароли хранятся исключительно в виде необратимого хеша; восстановление исходного пароля невозможно».

IP-адрес Роскомнадзор устойчиво относит к персональным данным. Журналы входов — часть ИСПДн, а не «технические логи вне периметра».

3. Что дописать в уже составленные документы

Документ	Что добавить
Политика (ГОТОВЫЕ_ДОКУМЕНТЫ/1)	Раздел о второй обработке: цели, основания, категории данных и субъектов, сроки хранения, порядок удаления учётной записи. Формулировка про хеш паролей. Указание, что IP и журналы входов обрабатываются в целях безопасности
Уведомление РКН (ГОТОВЫЕ_ДОКУМЕНТЫ/2)	Вторая цель обработки со своим набором сведений по ч. 3.1 ст. 22. Категория субъектов — «пользователи сервиса». Место нахождения базы данных
Модель угроз и акт УЗ (ГОТОВЫЕ_ДОКУМЕНТЫ/4)	База данных пользователей — новый объект защиты с постоянным хранением . Прежняя формулировка «персистентное хранилище отсутствует» становится неверной и должна быть исправлена. Новые угрозы — раздел 5 настоящего документа

Документ	Что добавить
Оферта	Раздел об обработке данных пользователя; порядок удаления учётной записи; сроки хранения после расторжения
Регламент инцидентов (ГОТОВЫЕ_ДОКУМЕНТЫ/3)	Компрометация базы учётных записей как отдельный тип инцидента — он затрагивает идентифицируемых субъектов, то есть уведомление по ч. 3.1 ст. 21 обязательно

4. Локализация базы данных

[ЗАКОН] Часть 5 статьи 18 в редакции ФЗ от 28.02.2025 № 23-ФЗ: запись, систематизация, накопление, хранение, уточнение и извлечение персональных данных граждан РФ с использованием баз данных, находящихся за пределами территории Российской Федерации, не допускаются.

Формулировка прямая и касается именно **баз данных**. Раньше этот запрет применительно к сервису был предметом толкования, поскольку персистентного хранилища не было. С появлением базы пользователей он применяется **буквально и без оговорок**.

Отсюда:

- Продуктивная база — **только на территории РФ**, в контуре ООО «ИНТЕРФОНИКА».
- **Локальная база на личном устройстве разработчика для продуктива не подходит.** Формально требование локализации она не нарушает (устройство в РФ), но делает личный компьютер информационной системой персональных данных со всеми обязанностями по статье 19 и с соответствующими последствиями при инциденте.
- Для разработки использовать **синтетические данные**. Реальные учётные записи в среде разработки не размещать.
- Управляемые базы данных зарубежных провайдеров — исключены.

5. Новые угрозы для модели угроз

№	Угроза	Меры
У-11	Утечка базы учётных записей (email, хеши паролей)	argon2id с индивидуальной солью; шифрование хранилища; ограничение доступа; отдельные учётные данные базы
У-12	Подбор пароля	Ограничение частоты попыток входа; блокировка после серии неудач; требования к сложности пароля
У-13	Перехват или подделка сессии	HttpOnly, Secure, SameSite; ротация идентификатора сессии при входе; ограниченный срок жизни

№	Угроза	Меры
У-14	Компрометация API-ключа	Хранение только хеша ключа; отображение полного значения один раз при выдаче; возможность отзыва; фиксация последнего использования
У-15	Повышение привилегий (member → admin → root)	Проверка роли на стороне сервера при каждом запросе; запрет изменения роли через клиентские параметры
У-16	Доступ к чужому аккаунту через некорректную фильтрацию	Фильтрация по <code>account_id</code> на уровне запроса к базе, а не на уровне интерфейса
У-17	Обход авторизации через Streamlit-клиент	<code>app.py</code> обращается к Python-бэкенду напрямую, минуя Next.js, — то есть минуя авторизацию и лимиты. Закрывать сетевым доступом либо не публиковать

Угроза У-17 отмечена особо. Она сводит на нет всю подсистему разграничения: если бэкенд принимает запросы напрямую, авторизация в Next.js обходится в один запрос. Проверка прав должна выполняться в Python-бэкенде, а не только во фронтенде.

6. Уровень защищённости — пересмотр не требуется

Показатель	Значение
Категория данных	Иные (email, хеш пароля, IP, история платежей). Специальные категории и биометрия отсутствуют
Субъекты	Не являются работниками оператора
Количество	Менее 100 000
Тип угроз	3-й

Вывод: УЗ-4 сохраняется. [ПРОВЕРИТЬ по тексту ПП РФ № 1119]

Уровень повысится при превышении 100 000 пользователей. Это следует отслеживать: рост числа зарегистрированных — не только коммерческий показатель, но и юридический триггер.

7. Платежи

- При приёме платежей через платёжного агрегатора **реквизиты карт не хранить**. Отсутствие хранения карточных данных снимает вопрос о применении PCI DSS.
- Хранить: идентификатор платежа во внешней системе, сумму, дату, статус. Этого достаточно для расчётов и учёта.

- Платательщик НПД формирует чек в приложении «Мой налог» по каждому поступлению. При большом числе мелких платежей требуется автоматизация — предусмотреть до запуска.
- Данные о платежах хранятся в сроки, установленные законодательством о налогах и сборах, — дольше, чем учётные данные. **Сроки хранения по категориям различаются, и в Политике их следует указать отдельно.**

8. Сроки хранения и удаление

Данные	Срок
Учётная запись	Срок действия договора
После удаления учётной записи	Уничтожение в срок, не превышающий 30 дней (ст. 21)
Журналы входов и действий	Определяется оператором; ориентир — 6–12 месяцев
Данные о платежах	По законодательству о налогах и сборах
История потребления	Срок действия договора; далее — обезличенная агрегированная статистика без привязки к субъекту

Право на удаление учётной записи должно быть реализовано **технически**, а не только описано в Политике: субъект вправе требовать уничтожения (ст. 21), и отказ по причине «функция не реализована» нарушением быть не перестаёт.

9. Что учесть в схеме данных до реализации

1. Отдельная таблица согласий: субъект, вид согласия, дата, версия документа, IP. Отзыв согласия — новая запись, а не изменение существующей.
2. Версионирование оферты и Политики: фиксировать, **какую именно редакцию** принял пользователь. При изменении условий это единственное доказательство.
3. Мягкое удаление (`deleted_at`) недостаточно для исполнения ст. 21 — требуется фактическое уничтожение. Предусмотреть процедуру, а не только флаг.
4. `account_id` и `user_id` в записях потребления — не только для биллинга: это и есть «регистрация действий, совершаемых с персональными данными» по п. 8 ч. 2 ст. 19.
5. Журнал `depersonalization_log.py` содержит поле `actor`, которое сейчас всегда пустое. **После ввода авторизации оно заполняется** — это закрывает пробел, отмеченный при его создании.

10. Порядок

1. Дописать Политику и Оферту разделами о второй обработке — **до открытия регистрации**.
2. Реализовать проверку прав в **Python-бэкенде**, а не только во фронтенде (угроза У-17).
3. Реализовать удаление учётной записи и данных.
4. Обновить модель угроз: убрать утверждение об отсутствии персистентного хранилища, добавить угрозы У-11...У-17.
5. Дополнить уведомление в Роскомнадзор второй целью обработки. Если уведомление уже подано — по ч. 7 ст. 22 не позднее 15-го числа месяца, следующего за месяцем изменений.